

General Playbook – Desktops and Servers

1. Firewall Everything (and allow the specific rules)
 - a. Default Inbound Rules: ICMP Ping
 - b. Default Outbound Rules: TCP 80/443 (HTTP), UDP 53 (DNS)
 - c. When allowing internally required services, use appropriate 172.20.X.0/24
 - d. Enable log denied, watch them
2. Change admin passwords
 - a. Includes locking out any other admin accounts
 - b. ALL admin passwords, not just your user login!
3. Upgrade critical services (kernel, libc, networked services)
 - a. Use the audit report to help

4. Verify network functionality (DNS + Internet connectivity)
 - a. DNS should be ~~172.20.242.200~~ (maybe 172.20.240.20?), fallback 8.8.8.8
 - b. Use the IP of the AD/DNS server matching your system's relative location (Windows is Internal IP, Linux is External IP)
5. Disable and stop non-essential services
 - a. Discriminate against those touching network
6. Search for privilege escalation vectors and remove them
7. Search for malware and remove it

8. Begin general monitoring
 - a. Login sessions
 - b. System Log
 - c. Firewall Log
9. If you don't need outbound DNS/HTTP/HTTPS, maybe remove or disable those outbound rules to reduce potential attack impact

General Playbook – Firewall Appliances

1. Disable remote administration interfaces (*only* allow HTTPS access, and only on the Internal MGMT interface)
2. Change the admin account password, disable any other admin accounts, remove any added SSH keys for the admin account
3. Download the software updates and install them
 - a. Reboot required; check with anyone behind your firewall first before you cut them off!
4. Add explicit rules per-box allowing the scored traffic inbound (+pings, by rulebook)
 - a. Make sure to enable counting hits on the rule so you know if it works at all
 - b. Look for an AD-related surprise if in AD zone; may need to allow inbound LDAP or similar (best to enable “most” AD ports from the other zone IP ranges but log all connections that trigger this for adding to a different rule)

5. Once all of the rules are working as intended (show hits after scoring run), disable the default “Allow Inbound” rules
 - a. Watch for a new score run to happen after applying- make sure it doesn’t take anything down, be ready to remove port limitations from a box or two
6. Add an explicit outbound traffic allowance for HTTP+HTTPS+DNS+ICMP Ping
 - a. Counters, again
7. Make sure there’s no outbound cross-zone traffic and allow any that’s required (i.e.
8. Once that works, delete the default outbound allow rule (hope it works!)

9. Wait for injects, AND
10. Watch for DNS-based C2 and black hole the domain to stop it from running

General Tips:

- When troubleshooting, use the workstations as much as possible, but also have members of the other boxes watch their connection logs (not usually in journal!)
- Remember that the zone without the scored service uses the External/Post-NAT IPs, not the internal IP address, so the workstations will refer to the same box with different IPs (use the other side’s for troubleshooting HTTP because IP addresses can matter)

Network Hosts – Regionals

<i>Machine</i>	<i>Internal IP (NAT)</i>	<i>External IP</i>	<i>Username</i>	<i>Old Password</i>	<i>Fixed Password</i>
Ubuntu E-Comm	172.20.242.30	172.25.22.11	sysadmin	changeme	Cav3Jumpy44
Fedora Webmail	172.20.242.40	172.25.22.39	sysadmin	changeme	ClearJ@m05
Splunk	172.20.242.20	172.25.22.9	root sysadmin admin	changemenow changemenow changeme	[lock] 336gladLam6 70M!ntHook
Ubuntu Workstation	DHCP	Dynamic	sysadmin	changeme	Swiftfac322
Server 2019 AD/DNS	172.20.240.102	172.25.22.155	administrator	!Password123	ma!nHand330
Server 2019 Web	172.20.240.101	172.25.22.140	administrator	!Password123	\$ummerDark025
Server 2022 FTP	172.20.240.104	172.25.22.162	administrator	!Password123	1253\$illyHill
Windows 11 Workstation	172.20.240.100	172.25.22.144	administrator UserOne	!Password123 ChangeMe123	CurlyJuic3894 42Fl@tbee
Palo Alto NGFW 1	172.20.242.150 172.20.242.254/24	172.16.101.254/24	admin	Changeme123	270coalStran
Palo Alto NGFW 2	172.20.240.200 172.20.240.254/24	172.16.102.254/24	admin	Changeme123	gray93Min+
VyOS Router	172.16.101.1/24 172.16.102.1/24	172.31.21.2/29	vyos	changeme	@ppleWild12
Machine	Internal IP (NAT)	External IP	Username	Old Password	Fixed Password

Extra Options (Document Here)

			<i>Plain3637p!g</i>
			6lueEwe2935
			Goo) 82fork
			618Keyw@rm
			Epic24#ook
			w@ter21Ultra
			Jollys#oe379
			\$uperfawn2276
			7300high6oot

Firewall Settings (Windows)

- Set using Group Policy, NOT the firewall editor!
 - `gpedit.msc`
 - Computer Configuration > Windows Settings > Security Settings > Windows Defender Firewall with Advanced Security > [Drop Down]
- (right click) Windows Defender Firewall – Local Group Policies > Properties
 - **UPDATE 2026: DO NOT SET THESE RULES UNTIL INBOUND/OUTBOUND RULES CONFIGURED WHEN AD IS ACTIVE**
 - Navigate to the active profile
 - check with PowerShell: `Get-NetConnectionProfile`
 - State: On
 - Inbound/Outbound Connections: Block
 - Logging > Customize
 - Name: Uncheck “Not Configured”
 - Log dropped packets: Yes
 - Settings > Customize
 - Allow local firewall rules: No
- Inbound Rules
 - Add pre-defined “Core Networking Diagnostics” (all rules)
 - Add a pre-defined rule for each system service (DC: *AD DC, DNS Srv., RPC Map, File&Print Sharing*)
- Outbound Rules
 - Add pre-defined “Core Networking” (all rules), File&Printer Sharing (if AD client, all rules)
 - Add port rule TCP 80,443 (name it “HTTP(S)”)
 - AD Client Rules (DC as dest IP restriction): Kerberos 88/TCP, LDAP 389/TCP/UDP (2 rules), RPC+Mapper 135+49152-65535/TCP
 - Add more if installed service requires other services
- Watch the log (leave open in new terminal)
 - PowerShell: `Get-Content -Wait C:\System32\LogFiles\Firewall\pfirewall.log`
 - Cross-reference PID (end of log line) with Task Manager Details view

Firewall Settings (Linux)

Use ufw (it's much easier). This may require disabling or removing firewalld. All ufw commands need root permissions.

By default, ufw will allow ICMP Echo (ping) regardless of other settings. Use these commands loosely in order:

TO...	USE...
CLEAR CONFIG	<code>ufw reset</code>
ENABLE	<code>ufw enable</code>
SHOW	<code>ufw status verbose</code>
DENY INCOMING	<code>ufw default deny incoming</code>
DENY OUTGOING	<code>ufw default deny outgoing</code>
ENABLE LOGS	<code>ufw logging low</code>
ALLOW BASIC SERVICES	<code>ufw allow out http; ufw allow out https; ufw allow out dns</code>
ALLOW NETWORK SERVICE (PARAMETERIZED)	<code>ufw allow in <service></code>

IMPORTANT: After using `ufw enable`, run `sudo systemctl enable --now ufw` to be 100% sure it is running.

Note: ufw MAY block outgoing pings by default. Add this to `/etc/ufw/before.rules`:

```
# allow outbound icmp
-A ufw-before-output -p icmp -m state --state NEW,ESTABLISHED,RELATED -j
ACCEPT
-A ufw-before-output -p icmp -m state --state ESTABLISHED,RELATED -j ACCEPT
```

Then, reload the firewall with `ufw reload` to allow pings to work.

System Auditing (Windows)

Tip: To run a program, use the Windows search bar (next to the start menu) with the name.

- HardeningKitty (<https://github.com/scipag/HardeningKitty>)
 - TODO: Command
- AutoRuns (<https://learn.microsoft.com/en-us/sysinternals/downloads/autoruns>)
 - Tip: Filter out Microsoft software (using the menus) for a shorter list
- `netstat -a -b -n`
- `lusrmgr.msc`
 - (On not-the-domain-controller)
 - Check the Administrators group
 - Make sure all users have passwords
- `appwiz.cpl`
 - Use this to uninstall unneeded applications
- `services.msc`
 - This isn't as helpful with AutoRuns on, but if a service is running that seems wrong, Google the setting to disable it
 - May also be needed to restore i.e. Defender or Windows Update
- `sysdm.cpl`
- `Compmgmt.msc`
- `nltest /[sc verify|dsgetdc|sc query]:domain-name`
 - Use these commands when troubleshooting an AD client
- Don't forget to update your required programs and services
- Run a Windows Defender full scan if you're leaving the machine alone for some time
 - Use a quick scan if you're still working on the box
- Malwarebytes kind of works, in a pinch (it will miss most things)
- Watch Task Manager!

System Auditing (Linux)

- Run lynis (<https://downloads.cisofy.com/lynis/lynis-3.1.4.tar.gz>)
 - Ignore advice about partitions, bootloader, and “service security”
 - Take advice for permissions and most other settings
- With the firewall online and using maximum strictness settings, leaving a `journalctl --follow` visible is a very good idea
 - Look for firewall denials, also look for unexpected service output
- Clear any SSH keys from users and root that aren’t actually needed
- `lsof -Pni` to look at ports
 - Add `-s TCP:LISTEN` for less work (but incomplete output)
- Run SUID3NUM
 - <https://raw.githubusercontent.com/Anon-Exploiter/SUID3NUM/refs/heads/master/suid3num.py>
- Check `/etc/passwd`
 - Look for unexpected user accounts, look for users with UID 0
 - Run `pwck` and `grpck`
- Check `/etc/shadow`
 - Make sure nobody has **empty** password (! is fine)
- Check `/etc/sudoers`
 - Use `visudo` and look for abnormal content
- Run `dpkg -V` or `rpm -Va`
 - a 5 in the output means “modified from stock”
- If no updates up front, make sure your repositories are enabled! (Look up defaults)
- Use `systemctl status` to look at all services
 - If Google doesn’t recognize it, disable and mask it
 - `systemctl disable --now <service> && systemctl mask <service>`
 - Masking a service ensures it can’t start
 - If the “enable by socket” message pops up when disabling a service, disable the socket then stop and disable the service again
- Install/run `aide` once hardening is finished to detect changes (look up the steps)

Using .htaccess

**MAKE SURE THAT THE IP ADDRESS RANGE ACTUALLY MATCHES THE SERVER'S RANGE
OR IT WON'T ACTUALLY WORK AND YOU'LL BE SAD**

Template A:

```
Require all denied
Require ip 172.20.240.0/24
```

Template B (apparently only one should work):

```
Order deny,allow
Deny from all
Allow from 172.20.240.0/24
```

These files work recursively, so they should be placed in the root of admin directories.

MAKE SURE TO TEST THAT THE SERVICE REMAINS FUNCTIONAL!

Note: The IP here is for a particular subnet! It allows the Ubuntu Workstation (and others in its network) to connect, but nothing outside.

Note: This only works when the server is using Apache, non-Apache servers can't use this.

Additional

(Read-Only mode, *maybe* use in http root if you have to, but this is a dubious read of the rules, and also this is not tested):

```
<LimitExcept GET HEAD>
    Require all denied
    Require ip 172.20.240.0/24
</LimitExcept>
```

Or

```
<LimitExcept GET HEAD>
    Order deny,allow
    Deny from all
    Allow from 172.20.240.0/24
</LimitExcept>
```